

DOCUMENTAÇÃO TÉCNICA

Portal de Conteúdo / Blog MOVE.ON

Arquitetura, requisitos, casos de uso, classes, banco de dados, segurança, operação e manutenção



Versão do documento: 1.0

Data de referência: 13 de agosto de 2026

Base documental: código-fonte e schema efetivamente implementados

Sumário

Controle e orientação do documento.....	4
Como utilizar esta documentação.....	4
Convenções visuais	4
1. Visão geral	5
1.1 Objetivos.....	5
1.2 Escopo funcional	5
1.3 Requisitos.....	5
1.4 Atores e responsabilidades.....	6
1.5 Atributos de qualidade	6
2. Arquitetura e decisões técnicas.....	6
2.1 Backend e frontend no mesmo repositório	7
2.2 REST em vez de GraphQL	7
2.3 Full-Text Search em vez de LIKE/ILIKE	8
2.4 Cursor em vez de OFFSET.....	8
2.5 SSE, Webhooks e tempo real	8
2.6 Imagens, vídeo e banda.....	8
2.7 SEO	8
3. Casos de uso	9
4. Diagrama e catálogo de classes.....	10
4.1 Relacionamentos.....	11
5. Modelagem completa do banco.....	11
5.1 controle_migrations	12
5.2 administradores	13
5.3 sessoes_administrativas	13
5.4 categorias	13
5.5 publicacoes.....	13
5.6 publicacoes_categorias.....	14
5.7 midias	14
5.8 configuracoes_portal	14
5.9 eventos_acesso	15
5.10 termos_busca.....	15
5.11 inscricoes_newsletter	15

5.12 envios_newsletter.....	16
5.13 Índices, integridade e retenção.....	16
6. Interface e funcionalidades.....	16
6.1 Portal público.....	19
6.1.1 Leitura orientada da tela pública.....	19
6.2 Dashboard.....	20
6.2.1 Leitura orientada do login e dashboard.....	20
7. Segurança.....	20
7.1 Matriz de ameaças e controles.....	21
7.2 Limites e recomendações de produção.....	21
8. Variáveis de ambiente.....	21
9. Estrutura do projeto.....	23
9.1 Fluxo de execução.....	23
10. Rotas e contratos HTTP.....	23
10.1 Regras transversais dos contratos.....	24
11. Catálogo de classes e funções.....	24
12. Operação, testes e manutenção.....	25
12.1 Estratégia de testes recomendada.....	25
12.2 Evolução arquitetural.....	26
13. Matriz de rastreabilidade.....	26
14. Glossário.....	26

Controle e orientação do documento

Objetivo desta seção	O que será apresentado
Estabelecer a finalidade, o público e os limites desta especificação.	Controle de versão, leitores esperados, fontes de verdade e convenções gráficas.

Item	Definição
Documento	Especificação Técnica do Portal de Conteúdo / Blog MOVE.ON
Versão	1.1 — revisão estrutural e ampliação descritiva
Data de referência	13 de agosto de 2026
Estado descrito	Implementação existente no repositório, migrations 0001 a 0007
Público-alvo	Desenvolvedores, arquitetos, DevOps, QA, segurança, produto e manutenção
Fontes de verdade	Código TypeScript/React, SQL das migrations, .env.example, Docker Compose e scripts
Tratamento de segredos	Apenas nomes e finalidades; valores reais do .env não são reproduzidos

Como utilizar esta documentação

- Para compreender o produto: leia Visão geral, Requisitos e Interface.
- Para alterar código: consulte Arquitetura, Classes e Catálogo de funções.
- Para alterar persistência: consulte Modelagem do banco, Índices e migrations.
- Para implantar: consulte Variáveis de ambiente, Estrutura e Operação.
- Para revisar riscos: consulte Segurança, limites de produção e testes recomendados.

Convenções visuais

Convenção	Significado
Vermelho #fe3000	Acento institucional e destaque de títulos, cabeçalhos e fronteiras.
<<Fronteira>>	Elemento que recebe ou apresenta interação ao usuário/sistema externo.
<<Controle>>	Elemento que coordena regras, fluxo de aplicação ou persistência.
<<Entidade>>	Informação persistida ou objeto conceitual do domínio.
Seta contínua	Dependência, chamada ou fluxo de dados.
Tabela vermelha/cinza	Cabeçalho de consulta rápida e linhas alternadas para leitura.

1. Visão geral

Objetivo desta seção	O que será apresentado
Apresentar o problema, o produto e suas fronteiras.	Objetivos, escopo, atores, requisitos funcionais e atributos de qualidade.

O MOVE.ON é um portal de conteúdo responsivo com área pública, leitura individual de artigos e dashboard administrativo protegido. O produto centraliza publicação, categorização, agendamento, mídia, SEO, compartilhamento, newsletter, identidade visual, perfil administrativo e métricas confiáveis em uma única base PostgreSQL.

1.1 Objetivos

- Publicar conteúdo acessível e otimizado para busca e compartilhamento.
- Oferecer administração segura sem cadastro público.
- Manter métricas reais, excluindo robôs, administradores e duplicidades diárias.
- Escalar a leitura por cache, índices, busca textual e paginação por cursor.
- Facilitar manutenção com módulos e nomenclaturas em português do Brasil.

1.2 Escopo funcional

- Portal inicial com destaque, feed incremental, categorias, busca e newsletter.
- Página canônica por slug com conteúdo formatado, SEO e compartilhamento.
- Dashboard: visão geral, publicações, editor, categorias, métricas, newsletter, aparência e administrador.
- PostgreSQL, migrations, seed, Docker Compose e instalador Ubuntu.

1.3 Requisitos

ID	Requisito	Tipo
RF01	Listar publicações publicadas e destaques	Funcional
RF02	Pesquisar por título, resumo, conteúdo e categoria	Funcional
RF03	Filtrar por múltiplas categorias	Funcional
RF04	Carregar feed por scroll infinito	Funcional
RF05	Ler artigo em URL amigável	Funcional
RF06	Compartilhar em redes sociais	Funcional
RF07	Cadastrar e cancelar newsletter	Funcional
RF08	Autenticar administrador	Funcional
RF09	Criar, visualizar, editar, excluir, agendar e arquivar publicação	Funcional
RF10	Gerenciar categorias	Funcional
RF11	Configurar identidade e cores	Funcional
RF12	Gerenciar perfil e revogar sessões ao trocar senha	Funcional
RF13	Consultar métricas confiáveis	Funcional
RF14	Editar conteúdo rico com imagens, vídeos e código	Funcional

Requisitos não funcionais: acessibilidade para baixa visão; responsividade; validação exclusiva no backend; cookies HttpOnly/Secure/SameSite; prevenção de XSS, CSRF e upload malicioso; SEO; desempenho; rastreabilidade; configuração externa por ambiente; disponibilidade compatível com implantação em VPS Ubuntu.

1.4 Atores e responsabilidades

Ator	Responsabilidade	Limite de acesso
Leitor	Descobrir, pesquisar, filtrar, ler, compartilhar e assinar/cancelar newsletter.	Somente recursos públicos.
Administrador	Gerir conteúdo, taxonomia, métricas, newsletter, identidade e perfil.	Rotas protegidas por sessão.
Agendador interno	Publicar itens vencidos e iniciar processamento da fila.	Processo interno sem interface pública.
Servidor SMTP	Receber e encaminhar mensagens profissionais.	Somente saída de e-mail configurada.
Crawler social/busca	Consumir HTML, metadados, sitemap e robots.	Conteúdo publicado e indexável.

1.5 Atributos de qualidade

Atributo	Como é atendido	Indicador esperado
Desempenho	FTS/GIN, cursor, lotes limitados, cache, lazy loading e mídia otimizada.	Baixo tempo de resposta e transferência proporcional ao viewport.
Segurança	Zod, sanitização, queries parametrizadas, cookies seguros, bcrypt e upload validado.	Entrada inválida recusada pelo backend.
Acessibilidade	Fontes e controles grandes, contraste, texto alternativo, foco e interface responsiva.	Navegação compreensível por teclado e baixa visão.
Manutenibilidade	Módulos por domínio, nomes em português e migrations incrementais.	Mudanças localizadas e rastreáveis.
Confiabilidade	Transações, constraints, fila persistente e métricas sem falsos positivos.	Estado consistente após falhas parciais.

2. Arquitetura e decisões técnicas

Objetivo desta seção	O que será apresentado
Explicar como a solução é dividida e por que as tecnologias foram escolhidas.	Camadas, comunicação, decisões REST/FTS/cursor, mídia, SEO e critérios para evolução.

MOVE.ON — Arquitetura integrada

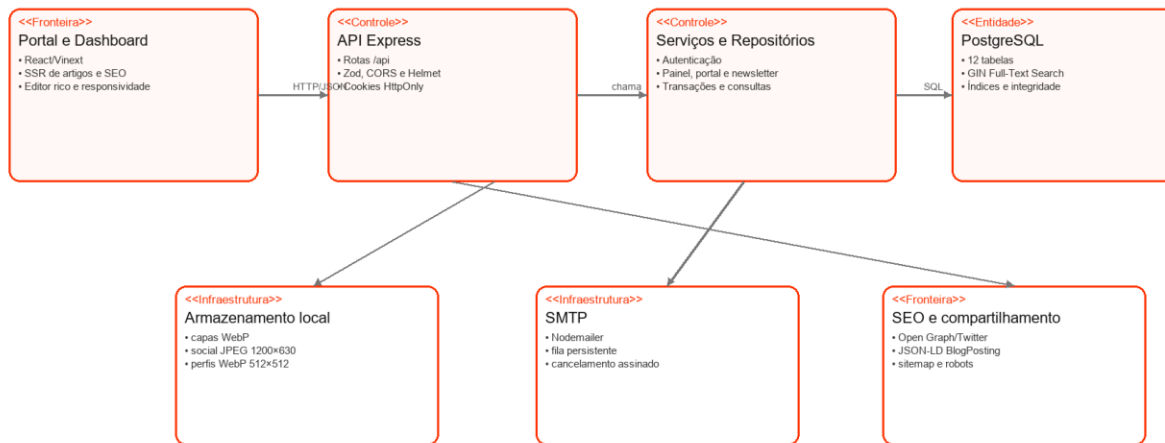


Figura 1 — Arquitetura lógica integrada do MOVE.ON.

Elemento visual	Interpretação funcional
Portal e Dashboard	Fronteiras React/Vinext. Exibem dados, coletam ações e nunca substituem a validação do servidor.
API Express	Ponto central de autenticação, autorização, validação, segurança HTTP e contratos JSON.
Serviços e Repositórios	Coordenam regras de negócio e isolam consultas/transações PostgreSQL.
PostgreSQL	Fonte de verdade de conteúdo, sessões, configurações, métricas e newsletter.
Armazenamento	Mantém arquivos gerenciados em diretórios separados por finalidade.
SMTP	Integração externa usada somente pelo processador persistente da newsletter.
SEO e compartilhamento	HTML e metadados consumidos por mecanismos de busca e redes sociais.

2.1 Backend e frontend no mesmo repositório

A solução adota um monorepositório modular: frontend Vinext/React e API Express são processos separados em execução, mas versionados, configurados e implantados juntos. A decisão reduz sobrecarga operacional para a VPS, preserva contratos próximos, unifica scripts, migrations e variáveis, e evita duplicação de tipos e pipelines. Não é um “arquivo único”: o backend está dividido em módulos, controladores, serviços, repositórios, validações e infraestrutura. A separação física em repositórios só se justificará quando equipes, ciclos de release ou escalabilidade forem independentes.

2.2 REST em vez de GraphQL

Os consumidores atuais possuem consultas previsíveis e endpoints específicos. REST com DTOs pequenos, paginação e cache é mais simples, observável e econômico. GraphQL adicionaria

parser, schema, proteção de profundidade/complexidade e risco de N+1 sem ganho mensurável neste domínio. Pode ser introduzido se surgirem múltiplos clientes com composições de dados muito diferentes.

2.3 Full-Text Search em vez de LIKE/ILIKE

LIKE/ILIKE tende a realizar varredura e comparação textual sem relevância linguística, especialmente com curingas iniciais. O MOVE.ON usa tsvector gerado, dicionário português, pesos A/B/C, websearch_to_tsquery e índices GIN. Isso normaliza termos, considera linguagem, melhora precisão e permite localizar candidatos por índice. A consulta também pesquisa o documento das categorias. O resultado é menor CPU, menor latência e escalabilidade superior.

2.4 Cursor em vez de OFFSET

A paginação pública usa cursor baseado em publicado_em. OFFSET exige descartar linhas anteriores e degrada conforme a página cresce; cursor permite continuar a partir do último registro indexado e mantém custo estável. O lote máximo de 30 impede respostas excessivas.

2.5 SSE, Webhooks e tempo real

SSE não foi adotado porque leitura, busca e administração não exigem conexão permanente; mantê-la para cada visitante aumentaria sockets e memória. Webhooks serão adequados quando houver integração externa que precise receber eventos, como provedor de e-mail ou CDN. A newsletter usa fila persistente e processamento periódico, evitando dependência da requisição de publicação.

2.6 Imagens, vídeo e banda

- Capas: WebP até 1600×1000, qualidade 84, rotação por EXIF e sem ampliação.
- Prévia social: JPEG progressivo 1200×630, qualidade 88.
- Perfil: WebP 512×512, leitura sequencial e redução inteligente.
- Conteúdo: loading=lazy e decoding=async; vídeo incorporado apenas por HTTPS e hosts permitidos.
- Arquivos estáticos: cache imutável de 30 dias.
- Cards fora do viewport: content-visibility para reduzir layout e pintura.

2.7 SEO

- Slugs exclusivos com hash criptográfico curto.
- Canonical por artigo, Open Graph, Twitter Card e imagem social.
- JSON-LD BlogPosting, Organization e WebSite.
- sitemap.xml e robots.txt; /admin e /api não indexáveis.
- Título, descrição, categorias, datas, imagem, texto alternativo e idioma pt-BR.

3. Casos de uso

Objetivo desta seção	O que será apresentado
Descrever objetivos observáveis dos usuários, sem misturar detalhes de implementação.	Atores, pré-condições, fluxo principal, alternativas e resultado esperado.

Casos de uso principais

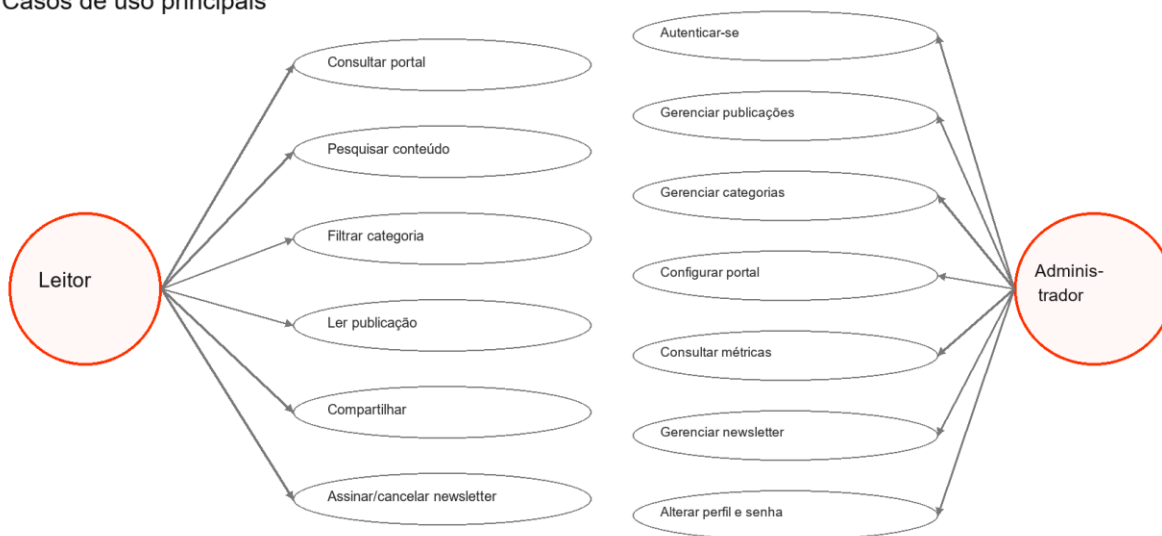


Figura 2 — Atores e casos de uso do portal.

Elemento visual	Interpretação funcional
Leitor	Ator público que consome e distribui conteúdo e controla sua inscrição.
Administrador	Ator autenticado responsável pela operação editorial e institucional.
Elipses centrais	Objetivos de negócio disponibilizados pelo sistema.
Linhas de associação	Indicam quais objetivos cada ator inicia ou utiliza.

Caso	Ator	Pré-condição	Fluxo resumido	Pós-condição
UC01 Consultar portal	Leitor	API e banco disponíveis	Carregar configurações, categorias e primeiro lote; rolar para novos lotes.	Feed exibido com cursor.
UC02 Pesquisar	Leitor	Portal aberto	Informar termos; aguardar debounce; executar FTS; exibir resultados.	Resultados relevantes sem varredura no cliente.
UC03 Ler e compartilhar	Leitor	Publicação publicada	Abrir slug; registrar visualização válida; escolher rede.	Artigo e metadados sociais disponíveis.
UC04 Newsletter	Leitor	E-mail válido	Inscriver; receber nova publicação; cancelar por token HMAC.	Inscrição ativa ou cancelada.
UC05 Autenticar	Administrador	Conta ativa	Validar limite, credenciais bcrypt, criar token e cookie.	Sessão persistida.
UC06 Publicar	Administrador	Sessão válida	Editar; selecionar categorias/status/destaque; enviar capa; pré-visualizar; salvar.	Publicação persistida e, se publicada, newsletter enfileirada.

Caso	Ator	Pré-condição	Fluxo resumido	Pós-condição
UC07 Alterar senha	Administrador	Senha atual correta	Gerar novo bcrypt; atualizar; revogar todas as sessões na mesma transação.	Todos os dispositivos deslogados.
UC08 Consultar métricas	Administrador	Sessão válida	Agregar eventos não robôs, não administrativos e únicos.	Painel de acessos reais.

4. Diagrama e catálogo de classes

Objetivo desta seção

Relacionar responsabilidades de software e dependências principais.

O que será apresentado

Fronteiras, controles, entidades conceituais, métodos e relacionamentos.

Diagrama de classes — visão completa por responsabilidade



Figura 3 — Classes e componentes classificados por estereótipo.

Elemento visual	Interpretação funcional
Faixa superior — Fronteiras	Componentes React e rotas SSR que conversam com usuários ou crawlers.
Faixa central — Controles	Controladores, serviços e repositórios que executam casos de uso.
Faixa inferior — Entidades	Registros persistentes do domínio e associações entre eles.
Setas verticais	Dependência da camada superior em uma responsabilidade inferior.

Classificação adotada: <<Fronteira>> representa interação com usuário ou sistema externo; <<Controle>> coordena regras, casos de uso e persistência; <<Entidade>> representa estado

persistente do domínio. Repositórios foram classificados como controle de persistência, e cada tabela possui uma entidade conceitual correspondente.

Classe/componente	Classificação	Responsabilidade
ControladorAutenticacao	<<Controle>>	Orquestra login, consulta e logout; emite/expira cookie.
ServicoAutenticacao	<<Controle>>	Valida senha, cria token, recupera administrador e encerra sessão.
RepositorioAutenticacao	<<Controle>>	SQL de administradores e sessões.
LimitadorLogin	<<Controle>>	Controla falhas e bloqueio temporário por origem.
ControladorPainel	<<Controle>>	Valida e coordena CRUD, upload, perfil, métricas e newsletter.
RepositorioPainel	<<Controle>>	Transações e consultas administrativas.
RepositorioPortal	<<Controle>>	Feed, cursor, FTS, artigo, eventos e inscrição.
ServicoNewsletter	<<Controle>>	Publica agendadas, cria fila, envia e retenta e-mails.
Portal	<<Fronteira>>	Página pública, tema, busca e scroll infinito.
Login	<<Fronteira>>	Formulário administrativo acessível.
Painel	<<Fronteira>>	Shell e navegação do dashboard.
Editor	<<Fronteira>>	Formulário completo de publicação.
EditorRico	<<Fronteira>>	Editor visual e mídia redimensionável.
Compartilhamento	<<Fronteira>>	Ações de redes sociais e topo/voltar.
ControleMigrations	<<Entidade>>	Representação conceitual da tabela controle_migrations.
Administradores	<<Entidade>>	Representação conceitual da tabela administradores.
SessoesAdministrativas	<<Entidade>>	Representação conceitual da tabela sessoes_administrativas.
Categorias	<<Entidade>>	Representação conceitual da tabela categorias.
Publicacoes	<<Entidade>>	Representação conceitual da tabela publicacoes.
PublicacoesCategorias	<<Entidade>>	Representação conceitual da tabela publicacoes_categorias.
Midias	<<Entidade>>	Representação conceitual da tabela midias.
ConfiguracoesPortal	<<Entidade>>	Representação conceitual da tabela configuracoes_portal.
EventosAcesso	<<Entidade>>	Representação conceitual da tabela eventos_acesso.
TermosBusca	<<Entidade>>	Representação conceitual da tabela termos_busca.
InscricoesNewsletter	<<Entidade>>	Representação conceitual da tabela inscricoes_newsletter.
EnviosNewsletter	<<Entidade>>	Representação conceitual da tabela envios_newsletter.

4.1 Relacionamentos

- Portal → RepositorioPortal por rotas públicas.
- Login → ControladorAutenticacao → ServicoAutenticacao → RepositorioAutenticacao.
- Painel/Editor → ControladorPainel → RepositorioPainel.
- ControladorPainel → ServicoNewsletter ao publicar.
- ServicoNewsletter → Nodemailer e PostgreSQL.
- Administrador 1:N SessaoAdministrativa e Publicacao.
- Publicacao N:N Categoria por PublicacaoCategoria.
- Publicacao 1:N Midia, EventoAcesso e EnvioNewsletter.
- InscricaoNewsletter 1:N EnvioNewsletter.

5. Modelagem completa do banco

Objetivo desta seção

O que será apresentado

Objetivo desta seção

Documentar integralmente a persistência e as regras de integridade.

O que será apresentado

Entidades, colunas, tipos, chaves, cardinalidades, índices e políticas de exclusão.

Modelo entidade-relacionamento — todas as tabelas

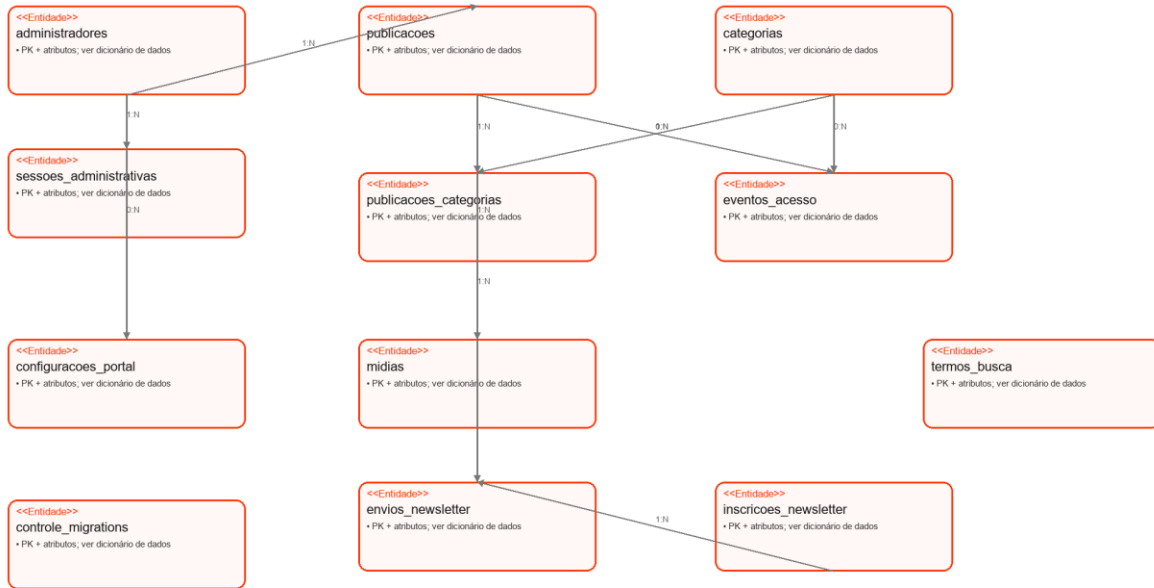


Figura 4 — Modelo de dados incluindo as 12 tabelas, inclusive controle_migrations.

Elemento visual	Interpretação funcional
administradores	Raiz do domínio administrativo; vincula sessões, publicações e alterações de configuração.
publicacoes e categorias	Núcleo editorial ligado em N:N por publicacoes_categorias.
eventos_acesso e termos_busca	Telemetria funcional e anonimizada para métricas e análise.
inscricoes/envios_newsletter	Cadastro e fila persistente com rastreamento de tentativas.
midias	Catálogo previsto para arquivos associados a publicações.
controle_migrations	Registro técnico que impede reaplicação de alterações de schema.

O banco utiliza UUID para entidades expostas, identity bigint para eventos/filas, timestamptz para consistência temporal, JSONB para conteúdo extensível, enums para estados fechados, FKs com políticas explícitas e índices parciais para caminhos críticos.

5.1 controle_migrations

Coluna	Tipo/restrição	Finalidade
nome	varchar(255), PK	Nome do arquivo aplicado
executada_em	timestamptz	Auditoria da execução

5.2 administradores

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Identificador
nome	varchar(120)	Nome
email	varchar(254), UNIQUE	Login
senha_hash	varchar(255)	Hash bcrypt
ativo	boolean	Habilitação
ultimo_acesso_em	timestamptz	Último login
criado_em	timestamptz	Criação
atualizado_em	timestamptz	Alteração
caminho_foto	varchar(500)	Foto WebP

5.3 sessoes_administrativas

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Sessão
administrador_id	uuid, FK	Administrador
token_hash	char(64), UNIQUE	SHA-256 do token
endereço_ip_hash	char(64)	IP anonimizado
agente_usuario	varchar(500)	Cliente
expira_em	timestamptz	Expiração
revogada_em	timestamptz	Revogação
criada_em	timestamptz	Criação

5.4 categorias

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Categoria
nome	varchar(80)	Nome
slug	varchar(100), UNIQUE	URL
descricao	varchar(300)	Descrição
ativa	boolean	Visibilidade
criado_em	timestamptz	Criação
atualizado_em	timestamptz	Alteração
documento_busca	tsvector gerado	FTS português

5.5 publicacoes

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Publicação
título	varchar(180)	Título
slug	varchar(200), UNIQUE	URL + hash curto
resumo	varchar(500)	Resumo
conteudo	jsonb	HTML higienizado

Coluna	Tipo/restrição	Finalidade
situacao	enum	rascunho/agendada/publicada/arquivada
destaque	boolean	Destaque
metatitulo	varchar(180)	SEO
metadescricao	varchar(320)	SEO
publicado_em	timestampz	Publicação
agendado_para	timestampz	Agendamento
administrador_id	uuid, FK	Responsável
criado_em	timestampz	Criação
atualizado_em	timestampz	Alteração
imagem_capa_url	varchar(1000)	Capa WebP/link
imagem_social_url	varchar(1000)	JPEG 1200×630
texto_alternativo_capa	varchar(300)	Acessibilidade/SEO
documento_busca	tsvector gerado	FTS ponderado

5.6 publicacoes_categorias

Coluna	Tipo/restrição	Finalidade
publicacao_id	uuid, PK/FK	Publicação
categoria_id	uuid, PK/FK	Categoria

5.7 midias

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Mídia
publicacao_id	uuid, FK	Publicação opcional
tipo	enum	imagem/vídeo/arquivo
nome_original	varchar(255)	Nome recebido
nome_armazenado	varchar(255), UNIQUE	Nome seguro
tipo_mime	varchar(100)	MIME
tamanho_bytes	bigint	Até 50 MiB
largura	integer	Pixels
altura	integer	Pixels
texto_alternativo	varchar(300)	Acessibilidade
ordem	integer	Ordenação
capa	boolean	Indica capa
criado_em	timestampz	Criação

5.8 configuracoes_portal

Coluna	Tipo/restrição	Finalidade
id	smallint, PK=1	Registro único
nome	varchar(120)	Nome
descricao	varchar(300)	Descrição
caminho_logo	varchar(500)	Logo

Coluna	Tipo/restrição	Finalidade
caminho_favicon	varchar(500)	Favicon
atualizado_por	uuid, FK	Administrador
atualizado_em	timestampz	Alteração
cor_primaria	varchar(7)	Cor principal
cor_fundo_claro	varchar(7)	Fundo claro
cor_fundo_escuro	varchar(7)	Fundo escuro
cor_texto_claro	varchar(7)	Texto claro
cor_texto_escuro	varchar(7)	Texto escuro
newsletter_assunto	varchar(180)	Modelo do assunto
newsletter_texto	text	Modelo do corpo

5.9 eventos_acesso

Coluna	Tipo/restrição	Finalidade
id	bigint identity, PK	Evento
tipo	enum	visualização/compartilhamento/busca/categoria
publicacao_id	uuid, FK	Publicação
categoria_id	uuid, FK	Categoria
identificador_visitante_hash	char(64)	Visitante anonimizado
endereço_ip_hash	char(64)	IP anonimizado
agente_usuario	varchar(500)	Cliente
referencia	varchar(1000)	Contexto
dados	jsonb	Extensão
ocorrido_em	timestampz	Horário
e_robo	boolean	Filtra robôs
e_administrador	boolean	Filtra equipe

5.10 termos_busca

Coluna	Tipo/restrição	Finalidade
id	bigint identity, PK	Busca
termo	varchar(200)	Texto
identificador_visitante_hash	char(64)	Visitante
quantidade_resultados	integer	Resultados
pesquisado_em	timestampz	Horário

5.11 inscricoes_newsletter

Coluna	Tipo/restrição	Finalidade
id	uuid, PK	Inscrição
email	varchar(254), UNIQUE	Destinatário
confirmada	boolean	Estado
token_confirmacao_hash	char(64)	Confirmação
inscrito_em	timestampz	Cadastro

Coluna	Tipo/restrrição	Finalidade
cancelado_em	timestamptz	Opt-out

5.12 envios_newsletter

Coluna	Tipo/restrrição	Finalidade
id	bigint identity, PK	Envio
inscricao_id	uuid, FK	Inscrito
publicacao_id	uuid, FK	Publicação
situacao	varchar(20)	pendente/enviando/enviado/falhou
tentativas	smallint	Retentativas
erro	varchar(1000)	Falha
criado_em	timestamptz	Fila
enviado_em	timestamptz	Entrega

5.13 Índices, integridade e retenção

- GIN em publicacoes.documento_busca e categorias.documento_busca.
- Índice parcial do feed por publicado_em/id para situação publicada.
- Índice único de visualização diária por publicação, visitante, data e tipo.
- Índices de métricas por data/tipo e publicação/data, excluindo robôs/administradores.
- Índice de sessões ativas e expiração.
- Índice da fila pendente/falha da newsletter.
- ON DELETE CASCADE em sessões, associações e fila; RESTRICT em publicação→administrador e categoria vinculada; SET NULL em eventos/configuração quando apropriado.

6. Interface e funcionalidades

Objetivo desta seção	O que será apresentado
Explicar a experiência visual e a função de cada área apresentada.	Portal, login, dashboard, componentes, comportamento responsivo e estados visuais.

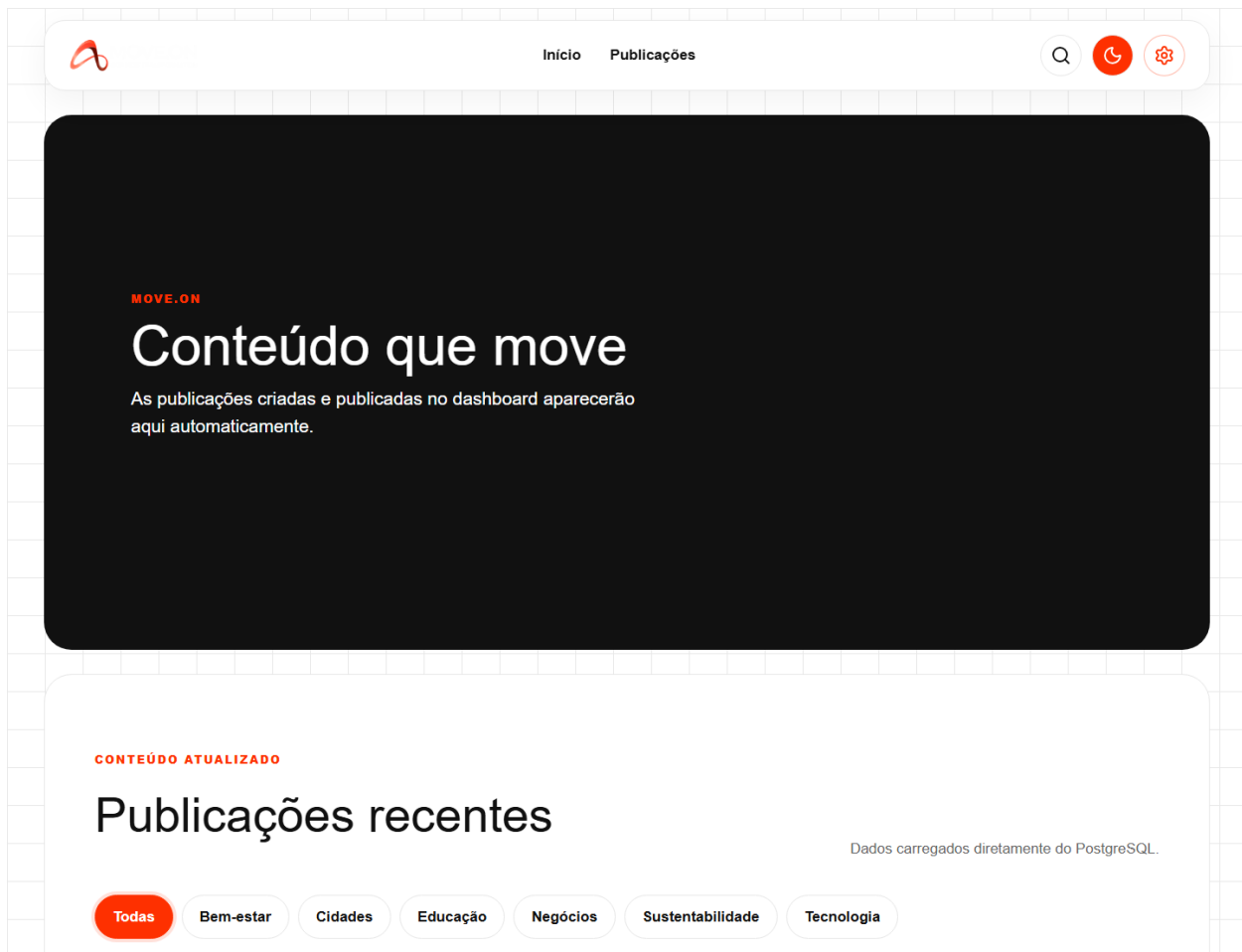


Figura 5 — Portal público: cabeçalho, busca modal, tema, acesso administrativo, destaque, categorias e feed incremental.

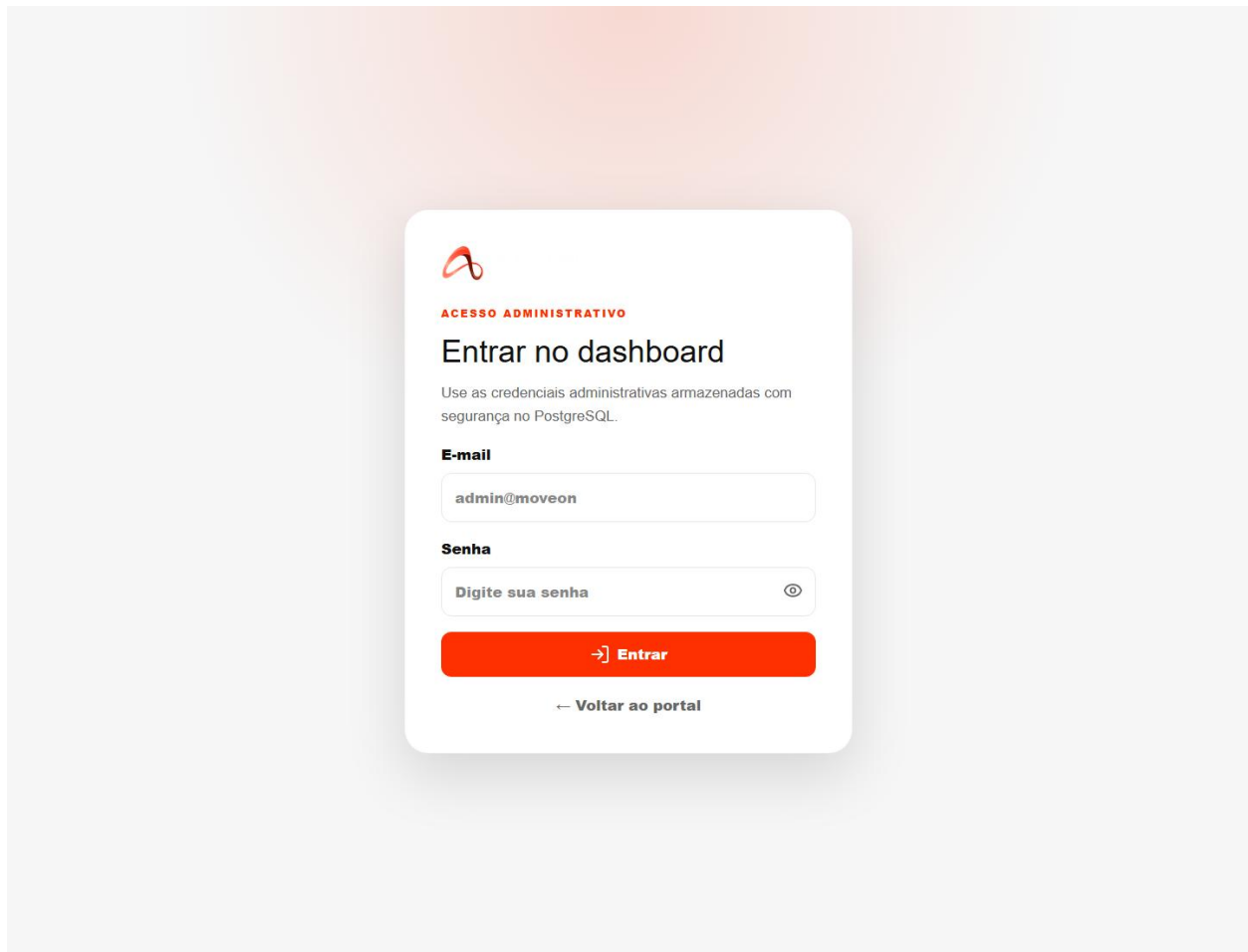


Figura 6 — Login: campos acessíveis, visualização de senha, proteção por limite de tentativas e sessão HttpOnly.

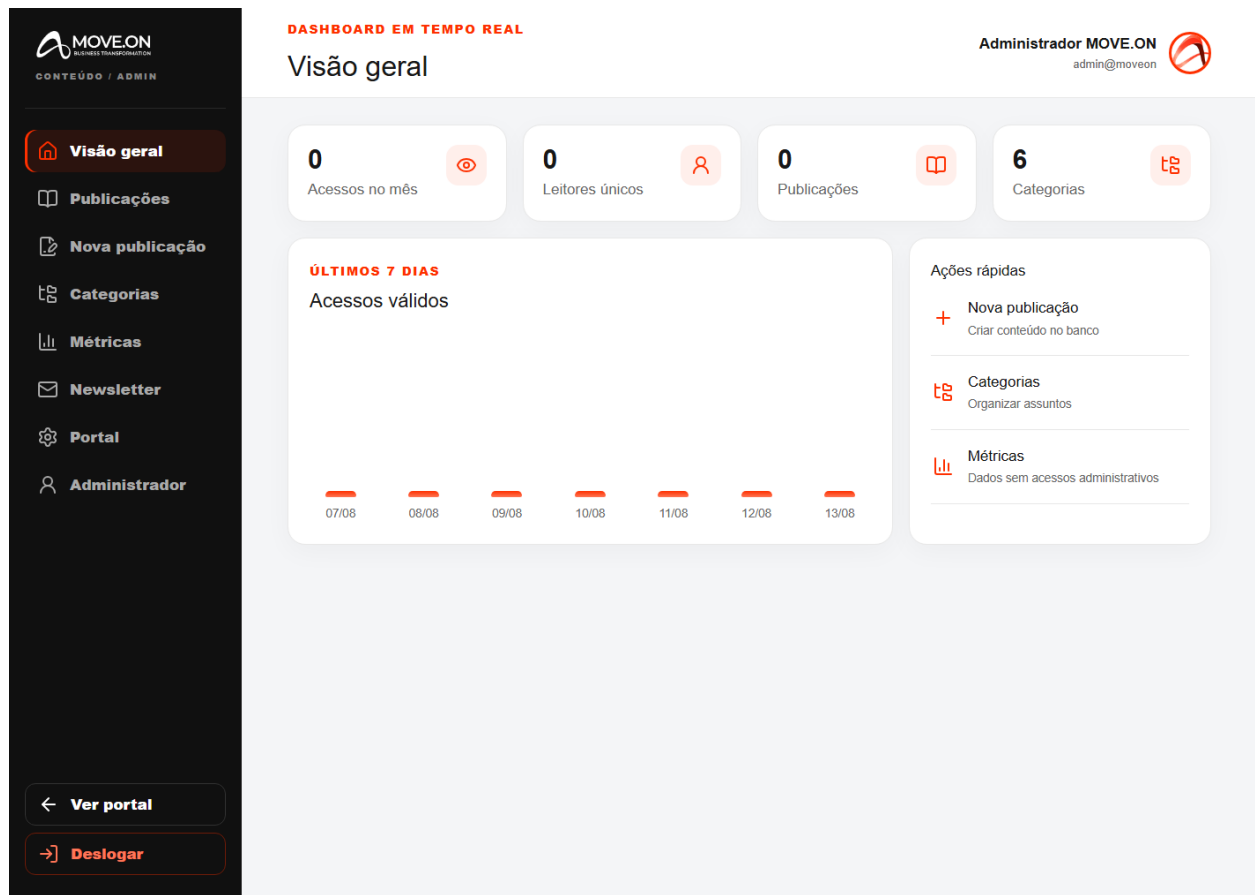


Figura 7 — Dashboard: métricas reais, gráfico, atalhos, navegação, perfil e logout.

6.1 Portal público

- Busca oculta em modal moderno; consulta FTS após debounce.
- Tema claro/escuro com preferências visuais e fundo quadriculado.
- Cards fixos, clicáveis, hover vermelho e categorias interativas.
- Scroll infinito e botão de topo apenas após rolagem.
- Restauração da posição ao voltar de um artigo.

6.1.1 Leitura orientada da tela pública

Elemento	Função	Comportamento visual
Marca	Identifica o portal e retorna ao início.	Logo no canto esquerdo com área de clique ampla.
Navegação	Acessa início e publicações.	Links centrais; menu compacto em telas pequenas.
Busca	Pesquisa título, resumo, conteúdo e categoria.	Ícone abre modal sobreposto, sem deslocar o cabeçalho.
Tema	Alterna claro e escuro.	Botão circular e cores/fundo atualizados.
Administração	Atalho para /admin.	Engrenagem à direita do botão de tema.
Destaque	Promove conteúdo editorial prioritário.	Bloco grande com imagem, texto e CTA visível.
Categorias	Refina o feed.	Pílulas com hover e estado ativo vermelho.
Cards	Resume cada publicação.	Altura uniforme, ponteiro de mão e borda

Elemento	Função	Comportamento visual
		animada.
Scroll infinito	Continua o feed sem paginação manual.	Sentinela solicita lotes por cursor.
Topo	Retorna rapidamente ao início.	Botão vermelho exibido somente após rolagem.

6.2 Dashboard

- Editor rico: headings, listas, alinhamento, links, remoção de links, fonte, tamanho, cores, código, imagem e vídeo redimensionáveis.
- Estados: rascunho, agendada, publicada e arquivada; destaque e múltiplas categorias.
- Upload ou URL de capa, pré-visualização e exclusão de arquivos gerenciados.
- Configuração de logo, favicon, cores, nome e descrição.
- Perfil com foto otimizada; e-mail/senha protegidos pela senha atual.
- Newsletter paginada, modelo editável e cancelamento automático.

6.2.1 Leitura orientada do login e dashboard

Elemento	Função	Regra relevante
Login	Inicia sessão administrativa.	Erro genérico, limite de tentativas e opção de revelar senha.
Menu lateral	Organiza os módulos administrativos.	Item atual destacado; compacto em telas pequenas.
Cabeçalho	Mostra contexto, nome, e-mail e foto.	Foto vem do estado persistido do administrador.
Cartões de métricas	Sintetizam acessos, leitores, publicações e categorias.	Excluem robôs e administradores.
Gráfico	Apresenta evolução de acessos válidos.	Série temporal diretamente agregada no banco.
Ações rápidas	Reduz passos para tarefas frequentes.	Atalhos para publicação, categorias e métricas.
Logout	Encerra somente a sessão atual.	Revoga token no banco e expira cookie.
Troca de senha	Atualiza credencial crítica.	Revoga todas as sessões, inclusive a atual.

7. Segurança

Objetivo desta seção	O que será apresentado
Explicar controles preventivos, detectivos e de recuperação.	Entradas, sessão, senha, upload, conteúdo HTML, privacidade, HTTP e recomendações de produção.

- Backend valida todas as entradas com Zod strict; frontend não é fonte de confiança.
- HTML higienizado por allowlist; links recebem noopener noreferrer; iframes limitados a YouTube/Vimeo HTTPS.
- Upload em memória com limite de bytes, magic bytes via file-type, nome UUID e recompressão Sharp.
- Cookies HttpOnly, SameSite configurável, Secure em produção, Path=/ e expiração.
- Tokens nunca são persistidos em claro; apenas SHA-256.
- Senhas bcrypt com custo configurável; troca revoga todas as sessões atomicamente.
- Helmet, CORS restrito, JSON limitado e x-powered-by desativado.

- Eventos armazenam hashes de IP/visitante; robôs e administradores são marcados e excluídos das métricas.
- Consultas parametrizadas evitam injeção SQL.
- Segredos ficam no .env, ignorado pelo Git; documentação não deve registrar valores reais.

7.1 Matriz de ameaças e controles

Risco	Controle implementado	Resultado
Injeção SQL	Parâmetros posicionais do driver pg.	Entrada não é concatenada ao SQL.
XSS persistente	sanitize-html por allowlist e iframe restrito.	Conteúdo perigoso é removido antes de persistir.
Roubo de sessão por script	Cookie HttpOnly e token somente em hash no banco.	JavaScript não lê o cookie; vazamento do banco não expõe token em claro.
CSRF	SameSite configurável, CORS restrito e JSON estrito.	Redução de requisições autenticadas entre origens.
Força bruta	Limitador por endereço e bcrypt configurável.	Tentativas repetidas sofrem bloqueio temporário.
Upload malicioso	Limite de bytes, magic bytes, recompressão e nome UUID.	Arquivo original não é servido diretamente.
Falso positivo em métricas	Deteção de robô/admin e unicidade diária.	Indicadores refletem audiência pública válida.
Sessão antiga após senha nova	Revogação global na mesma transação da senha.	Todos os dispositivos precisam autenticar novamente.

7.2 Limites e recomendações de produção

- COOKIE_SEGURO=true atrás de HTTPS.
- Rotacionar ADMIN_SENHA, POSTGRES_SENHA, SMTP_SENHA e EMAIL_SEGREDO_CANCELAMENTO.
- Persistir uploads em volume/backups ou armazenamento de objetos em escala horizontal.
- Aplicar reverse proxy com TLS, compressão, rate limiting distribuído e CDN.
- Monitorar fila, pool, latência, erros e espaço em disco.

8. Variáveis de ambiente

Objetivo desta seção	O que será apresentado
Centralizar configuração mutável e separar segredos do código.	Catálogo completo, finalidade, impacto operacional e cuidados de produção.

Todas as variáveis configuráveis e sensíveis ficam em .env. O arquivo .env.example documenta chaves sem expor valores reais. Segredos nunca devem ser incluídos em logs, commits ou documentação compartilhada.

Variável	Finalidade e importância
NODE_ENV	Modo de execução: development, test ou production. Controla comportamento seguro e otimizações.

Variável	Finalidade e importância
FUSO_HORARIO	Fuso operacional do portal, datas, métricas e PostgreSQL.
NOME_PORTAL	Nome institucional usado em interface, SEO e e-mails.
DESCRICAO_PORTAL	Descrição padrão do portal e metadados.
URL_PUBLICA_PORTAL	Origem canônica absoluta para SEO, compartilhamento e links da newsletter.
CAMINHO_LOGO	Logo padrão pública.
CAMINHO_FAVICON	Ícone padrão do navegador.
CAMINHO_IMAGEM_SOCIAL	Imagem social padrão quando a publicação não possui capa.
HOST_API	Interface de rede em que a API escuta.
PORTA_API	Porta HTTP da API Express.
URL_INTERNA_API	Endereço utilizado pelo frontend/proxy para alcançar a API.
ORIGENS_PERMITIDAS	Lista CORS de origens autorizadas.
LIMITE_CORPO_JSON	Limite do corpo JSON contra abuso de memória.
PASTA_UPLOADS	Diretório persistente de arquivos enviados.
MAX_IMAGEM_CAPA_MB	Tamanho máximo em bytes convertido para MB; a resolução é otimizada pelo Sharp.
EMAIL_ATIVO	Liga/desliga o processamento real dos envios.
SMTP_HOST	Servidor SMTP.
SMTP_PORTA	Porta SMTP.
SMTP_SEGURO	Ativa conexão TLS direta quando aplicável.
SMTP_USUARIO	Usuário SMTP; segredo.
SMTP_SENHA	Senha SMTP; segredo.
EMAIL_REMETENTE_NOME	Nome visível do remetente.
EMAIL_REMETENTE_ENDERECO	Endereço From dos e-mails.
EMAIL_SEGREDO_CANCELAMENTO	Segredo HMAC dos links de cancelamento.
POSTGRES_IMAGEM	Tag da imagem Docker do PostgreSQL.
POSTGRES_CONTAINER	Nome do container.
POSTGRES_HOST	Interface publicada pelo Docker.
POSTGRES_PORTA	Porta exposta no host.
POSTGRES_PORTA_INTERNA	Porta interna do PostgreSQL.
POSTGRES_BANCO	Nome do banco.
POSTGRES_USUARIO	Usuário do banco; segredo operacional.
POSTGRES_SENHA	Senha do banco; segredo.
DATABASE_URL	String de conexão completa usada pela aplicação; segredo.
BANCO_MAX_CONEXOES	Tamanho máximo do pool.
BANCO_TEMPO_OCIOSO_MS	Tempo para liberar conexão ociosa.
BANCO_TEMPO_CONEXAO_MS	Timeout para abrir conexão.
NOME_COOKIE_SESSAO	Nome do cookie administrativo.
DURACAO_SESSAO_DIAS	Validade máxima da sessão.
COOKIE_SAMESITE	Política SameSite contra CSRF.
COOKIE_SEGURO	Exige HTTPS para envio do cookie em produção.
MAX_TENTATIVAS_LOGIN	Limiar do limitador de autenticação.
JANELA_TENTATIVAS_MINUTOS	Janela temporal do bloqueio de login.
CUSTO_HASH_SENHA	Custo bcrypt.
ADMIN_NOME	Nome do administrador criado/atualizado pela semente.
ADMIN_EMAIL	E-mail inicial do administrador.
ADMIN_SENHA	Senha inicial; deve ser rotacionada.
CATEGORIAS_INICIAIS	Categorias inseridas pela semente.

9. Estrutura do projeto

Objetivo desta seção	O que será apresentado
Orientar desenvolvedores sobre onde localizar e alterar cada responsabilidade.	Pastas, módulos, fluxo de execução e fronteiras de manutenção.

Caminho	Responsabilidade
app/	Rotas e fronteiras React/Vinext; portal, admin, artigo, SEO, robots e sitemap.
backend/configuracoes/	Validação central do ambiente.
backend/compartilhado/	Cookies, autenticação obrigatória, erros, criptografia e sanitização.
backend/infraestrutura/banco/	Pool, migrations e semente.
backend/modulos/autenticacao/	Login, sessão, limite e persistência.
backend/modulos/painel/	CRUD, métricas, configurações, uploads e administrador.
backend/modulos/portal/	Feed, FTS, artigos, eventos e inscrições.
backend/modulos/newsletter/	Fila, SMTP e cancelamento.
backend/modulos/saude/	Health check.
migrations/	Evolução incremental do PostgreSQL.
scripts/	Instalação, migration e seed.
uploads/	Arquivos gerenciados por tipo.
public/	Logo, favicon e imagem social padrão.
documentacao/	Artefatos, diagramas, capturas e documento final.

9.1 Fluxo de execução

- npm run dev inicia portal e API simultaneamente.
- A API abre pool PostgreSQL e worker periódico da newsletter.
- Vite encaminha /api e /uploads para a API no desenvolvimento.
- Docker Compose mantém PostgreSQL em volume nomeado.
- migrar.ts aplica somente migrations ainda não registradas.
- semear.ts atualiza dados iniciais de forma repetível.

10. Rotas e contratos HTTP

Objetivo desta seção	O que será apresentado
Catalogar a superfície da API e seus requisitos de acesso.	Métodos, caminhos, autenticação, finalidade, respostas e regras transversais.

Método	Rota	Acesso	Finalidade
GET	/api/saude	Público	Saúde e banco
POST	/api/autenticacao/entrar	Público	Cria sessão
GET	/api/autenticacao/sessao	Cookie	Consulta sessão
POST	/api/autenticacao/sair	Cookie	Revoga sessão

Método	Rota	Acesso	Finalidade
GET	/api/portal/inicial	Público	Configuração, categorias e lote
GET	/api/portal/publicacoes	Público	FTS/categoria/cursor
GET	/api/portal/publicacoes/:slug	Público	Artigo publicado
POST	/api/portal/eventos	Público	Métrica validada
POST	/api/portal/newsletter	Público	Inscrição
GET	/api/portal/newsletter/cancelar	Token	Cancelamento
GET/POST/PUT /DELETE	/api/painel/publicacoes	Admin	CRUD
GET/POST/PUT /DELETE	/api/painel/categorias	Admin	CRUD
POST	/api/painel/uploads/capas	Admin	Capa otimizada
POST	/api/painel/uploads/perfil	Admin	Perfil otimizado
GET	/api/painel/metricas	Admin	Métricas
GET/PUT	/api/painel/configuracoes	Admin	Identidade
GET/PUT	/api/painel/administrador	Admin	Perfil/segurança
GET/DELETE	/api/painel/newsletter	Admin	Inscritos
GET/PUT	/api/painel/newsletter-modelo	Admin	Modelo

10.1 Regras transversais dos contratos

- Todas as rotas administrativas passam por exigirAutenticacao.
- Corpos JSON respeitam LIMITE_CORPO_JSON e validação estrita.
- Uploads usam multipart, um arquivo por requisição e limite configurado.
- Erros retornam mensagem pública sem detalhes internos ou credenciais.
- Listagens públicas usam limite máximo e cursor; newsletter administrativa usa paginação.
- Conteúdo público recebe cabeçalhos de cache coerentes; sessão e busca dinâmica usam no-store.

11. Catálogo de classes e funções

Esta seção relaciona os elementos executáveis relevantes. Métodos CRUD individuais aparecem nas classes de controle e repositório; funções de interface aparecem como fronteiras.

Objetivo desta seção	O que será apresentado
Permitir localizar rapidamente a regra responsável por cada comportamento.	Funções compartilhadas, classes backend, componentes frontend e efeitos colaterais.

Função/módulo	Descrição
criarAplicacao	Monta Express, Helmet, CORS, JSON, arquivos estáticos, rotas e erros.
executarMigrations	Aplica migrations ordenadas uma única vez.
executarSemente	Insere/atualiza administrador, categorias e configuração inicial.
gerarTokenSeguro / gerarHashSha256	Cria tokens e hashes criptográficos.
higienizarConteudoHtml	Remove HTML perigoso e força lazy loading em mídia.
lerCookie / criarCookieSessao / criarCookieExpirado	Manipula sessão HttpOnly/Secure/SameSite.
exigirAutenticacao	Autoriza rotas administrativas consultando sessão persistida.

Função/módulo	Descrição
armazenarCapa	Valida formato real e gera WebP + JPEG social.
armazenarFotoPerfil	Valida e converte foto de alta resolução para WebP 512×512.
fotoPerfilExiste / excluirFotoPerfil	Evita referências órfãs e remove arquivo gerenciado.
criarSlug	Normaliza título e acrescenta hash aleatório curto.
generateMetadata	Gera canonical, Open Graph, Twitter e metadados do artigo.
sitemap / robots	Expõe descoberta e regras de indexação.
registrar	Envia eventos válidos e anonimizados.
api	Cliente HTTP unificado com credenciais e erros.
EditorRico	Edição HTML, links, cores, fontes, mídia e redimensionamento.
InscricaoNewsletter	Cadastro público com validação.
Compartilhamento	WhatsApp, Instagram, LinkedIn, Facebook, X, Telegram, e-mail e Web Share.

Classe/grupo	Métodos e comportamento
RepositorioPainel	resumo; listar/obter/salvar/excluir publicações; listar/criar/atualizar/excluir categorias; metricas; configurações; administrador; newsletter. salvarPublicacao e atualizarAdministrador usam transações.
ControladorPainel	enviarCapa; enviarFotoPerfil; resumo; CRUD de publicações/categorias; métricas; configurações; administrador; lista/modelo newsletter. Higieniza conteúdo e coordena arquivos/fila.
RepositorioPortal	inicial; listarPublicacoes com FTS/cursor; obterPublicacaoPorSlug; registrarEvento; newsletter.
RepositorioAutenticacao	buscar por e-mail/token; registrar acesso; criar e revogar sessão.
ServicoAutenticacao	autenticar; obterAdministrador; encerrarSessao.
ControladorAutenticacao	entrar; consultarSessao; sair.
ServicoNewsletter	publicarAgendadas; enfileirar; processar; tokenCancelamento; idTokenValido.
Fronteiras React	ModalGlobal; Login; Portal; InscricaoNewsletter; Painel; Inicio; Grafico; Publicacoes; EditorRico; Editor; Categorias; Metricas; Configuracao; DadosAdmin; PainelNewsletter; Compartilhamento.

12. Operação, testes e manutenção

Objetivo desta seção	O que será apresentado
Definir como preparar, validar, executar e evoluir a aplicação com segurança.	Comandos, backup, observabilidade, testes, implantação e critérios de evolução.

- Desenvolvimento: npm run dev.
- Banco: npm run banco:subir; npm run banco:migrar; npm run banco:semear.
- Validação: npm run tipos e npm run build.
- Produção: configurar .env, HTTPS/reverse proxy, banco/volume e executar start:producao.
- Backup: volume PostgreSQL, uploads e .env em cofre separado.
- Observabilidade recomendada: logs estruturados, métricas de pool, HTTP, fila e disco.

12.1 Estratégia de testes recomendada

- Unitários: slug, tokens HMAC, sanitização, validações Zod e limitador.

- Integração: repositories em PostgreSQL descartável; transações e constraints.
- API: autenticação, autorização, CRUD, FTS, cursor, upload e newsletter.
- E2E: portal→artigo→voltar; dashboard→publicar; troca de senha→sessões revogadas.
- Carga: feed, artigo e FTS com dados representativos; observar p95/p99.
- Segurança: XSS, upload polyglot, CSRF, sessão, brute force e dependências.

12.2 Evolução arquitetural

Quando o volume justificar, os primeiros passos são CDN para mídia/HTML público, armazenamento de objetos, Redis para rate limit/cache/fila, múltiplas réplicas stateless da API e réplica de leitura PostgreSQL. GraphQL, SSE ou webhooks devem entrar apenas com caso de uso medido: composição variável entre clientes, atualização realmente ao vivo ou integração orientada a eventos, respectivamente.

13. Matriz de rastreabilidade

Objetivo desta seção	O que será apresentado	
Relacionar necessidades do produto às decisões e arquivos que as implementam.	Necessidade, mecanismo técnico e localização de referência.	

Necessidade	Mecanismo	Implementação
Busca precisa	documento_busca + GIN + websearch_to_tsquery	0007 / RepositorioPortal
Escala do feed	cursor + limite + IntersectionObserver	RepositorioPortal / Portal
SEO	slug, metadata, JSON-LD, sitemap, robots	0006 / app/publicacao
Métricas reais	hashes, filtros e unicidade diária	0003 / eventos_acesso
Segurança de sessão	token hash, cookie e revogação global	autenticacao / painel
Mídia leve	Sharp, WebP/JPEG, lazy/async	armazenamento-capas / sanitização
Newsletter	inscrição, fila, SMTP e HMAC	0005 / ServicoNewsletter
Configuração	env validado e configuração persistida	ambiente / configuracoes_portal

14. Glossário

Objetivo desta seção	O que será apresentado
Uniformizar o vocabulário usado no código e neste manual.	Termos de busca, desempenho, sessão, SEO e segurança.

Termo	Definição
FTS	Full-Text Search; indexação linguística de documentos.
GIN	Índice invertido do PostgreSQL adequado a tsvector.
Cursor	Marcador opaco do último item para paginação.
SSR	Renderização no servidor; importante para SEO e crawlers sociais.
Open Graph	Metadados usados em prévias de links.
JSON-LD	Dados estruturados serializados em JSON.

Termo	Definição
HMAC	Assinatura autenticada usada no cancelamento da newsletter.
HttpOnly	Cookie inacessível ao JavaScript.
SameSite	Restrição de envio de cookie entre sites.
LCP	Largest Contentful Paint; métrica de carregamento visual.

Fim da documentação. Este documento descreve o estado implementado na data de referência. Qualquer alteração de schema, rota, variável ou fluxo deve atualizar simultaneamente migrations, .env.example, README e esta documentação.